

funbox 2

Target ma'lumotlari

- IP address: 10.172.97.93
 - OS: Linux (taxmin: Ubuntu)
 - Test vaqti: 2026-09-10 06:11 (+05)
 - Attacker IP: 10.172.97.18
-

Penetratsion test hisoboti

1) Qisqa xulosa (Executive Summary)

Ushbu tekshiruvda lokal tarmoqda host discovery (ARP scan), port/servis aniqlash (Nmap) hamda web kataloglarni qidirish (Gobuster) ishlari bajarildi. Nishon sifatida 10.172.97.93 tanlandi. Skanda nishonda **SSH (22)**, **DNS (53)** va **HTTP (80)** ochiq ekani aniqlandi. Web servisdagi "Portfolio" sahifasi ko'rindi va katalog enumeration natijasida **/admin/** sahifasi topildi. **/admin/** sahifasi ichida **fayl yuklash (file upload)** funksiyasi mavjudligi aniqlandi; bu esa file-upload orqali **initial access** olish (masalan, web shell yoki upload bypass) ehtimolini beradi.

2) Muhit va doira (Scope & Environment)

- Test muhiti (attacker): Linux
- Tarmoq turi: lokal tarmoq (LAN)
- Nishon: bitta host (10.172.97.93) doirasida tekshiruv

3) Recon / Enumeration

3.1 Host discovery (ARP Scan)

Command: `sudo arp-scan -l`

Maqsad: lokal tarmoqdagi faol hostlarni aniqlash (IP ↔ MAC) va nishon IP'ni

topish.

Natija: 2 ta host javob berdi. Nishon sifatida quyidagi host ajratildi:

- `10.172.97.93` (MAC: `08:00:27:1c:59:b9`)

Eslatma: MAC vendor fayllariga ruxsat bo'lmagani sabab "Unknown" chiqdi; bu natijaga ta'sir qilmaydi.

3.2 Port scan (Nmap)

Command: `nmap -p- 10.172.97.93 -T4 -A`

Maqsad: barcha TCP portlarni tekshirish (`-p-`), servis/versiyalarni aniqlash (`-A`), skanni tezlashtirish (`-T4`).

Natija (ochiq portlar):

- `22/tcp` — SSH: `OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13`
- `53/tcp` — DNS: `ISC BIND 9.9.5-3ubuntu0.19`
- `80/tcp` — HTTP: `Apache 2.4.7 (Ubuntu)` (title: **Portfolio**)

3.3 Web servisni brauzerda tekshirish

Maqsad: 80-port ochiq chiqqani uchun web ilovani ko'rish va hujum nuqtalarini aniqlash.

Amal: `http://10.172.97.93` brauzerda ochildi.

Natija: "Portfolio" (John Doe) ko'rinishidagi sahifa chiqdi.

3.4 Katalog enumeration (Gobuster)

Command: `gobuster dir -u http://10.172.97.93 -w /usr/share/wordlists/dirb/common.txt`

Maqsad: yashirin katalog/fayllarni topish (admin panel, upload folder va h.k.).

Natija (muhim topilmalar):

- `/admin/` (301) — admin katalogi
- `/uploads/` (301) — upload katalogi
- `robots.txt` (200)
- `server-status` (403)

3.5 /admin/ sahifasi: File Upload funksiyasi

Maqsad: `/admin/` ichida aniqlangan file upload funksiyasi orqali initial access olish ehtimolini tekshirish (masalan, web shell yuklash yoki file upload bypass).

Amal: `http://10.172.97.93/admin/` ochildi va "Upload Your File" form ko'rindi.

Natija: Fayl yuklash oynasi mavjudligi tasdiqlandi. Keyingi bosqichda server qaysi fayl turlarini qabul qilishi, upload qayerga saqlanishi va bajarilish (execution) bo'lish-bo'lmasligi tekshiriladi.

4) Initial Access

- Qanday kirildi: **File upload** orqali web shell/reverse shell yuklab, serverda buyruq bajarish imkoniyati olindi.
- Dalillar: serverda quyidagi fayllar ko'rindi: `rev_shell.php`, `shell.php`, `test_ping.php` va boshqalar.

4.1 Upload qilingan shell orqali tizimga kirish (foothold)

Maqsad: `/admin/` sahifasidagi file upload funksiyasi orqali serverda buyruq bajarish (RCE) yoki reverse shell olish. Bu muvaffaqiyatli bo'lsa, nishon tizimga dastlabki kirish (initial access) olinadi.

Amal: upload orqali PHP shell/reverse shell fayllar yuklandi va ishga tushirildi. Shell ichida kataloglar ko'rildi va tizim bo'ylab navigatsiya qilindi:

- `ls`
- `cd /`, `ls`
- `cd /home/user`

Natija: Shell orqali nishon tizimida buyruqlar bajarilishi tasdiqlandi va `/home/user` ichida flag fayllari topildi:

- `flag.txt`
- `local.txt`

4.2 1-flag (user/local)ni olish

Maqsad: Initial access olinganini amaliy tasdiqlash va user darajasidagi flagni topish.

Amal:

- `cat flag.txt` → *"Flag is in another file"*
- `cat local.txt`

Natija: 1-flag `local.txt` faylidan olindi:

- `75544659536e36a500a2144e1c88bf42b0a510fc22f9755aa684a578de0f720b`

5) Post-Exploitation

- Ichki enumeration:
 - Web shell ichida tizim fayllari va foydalanuvchi ma'lumotlarini ko'rish
 - Credential qidirish (config/fayllar, userlar)
- Topilmalar:

5.1 /etc/passwd faylini tekshirish (hash topilishi)

Maqsad: Tizimga kirilgandan so'ng foydalanuvchilar va autentifikatsiya bilan bog'liq ma'lumotlarni topish. Ba'zi noto'g'ri sozlangan tizimlarda `/etc/passwd` (yoki `/etc/shadow`) ichida parol hash'lari ochiq qolishi mumkin. Bu holat credential olish va keyingi bosqichga o'tishga sabab bo'ladi.

Amal:

- `cat /etc/passwd`

Natija: `user` foydalanuvchisi uchun parol hash'i ko'rindi (MD5-crypt ko'rinishi):

- `user:$1$salt$vXU2YSCACW4wH//EMYUuB/:1000:1000:,,,:/home/user:/bin/bash`

Xulosa: Parol hash'ining `/etc/passwd` ichida ochiq turishi **jiddiy misconfiguration** hisoblanadi. Bu hash offline tarzda crack qilinib, haqiqiy parol olinishi mumkin.

5.2 Hash'ni yechish (crack) va SSH orqali kirish

Maqsad: topilgan hash'ni offline yechib, real parolni aniqlash va web shell'dan ko'ra barqarorroq kirish usuli — **SSH** orqali tizimga to'g'ridan-to'g'ri login qilish.

Amal: hash yechildi (offline cracking) va quyidagi parol olindi:

- `kkeenn`

So'ng SSH orqali kirildi:

- `ssh user@10.172.97.93`

Natija: `user` akkaunti uchun topilgan parol ishladi va SSH orqali tizimga kirish amalga oshdi.

6) Privilege Escalation

- Vektor:
- Dalillar:

7) Flaglar

- User/local flag: `75544659536e36a500a2144e1c88bf42b0a510fc22f9755aa684a578de0f720b`
- Root flag:

8) Tavsiyalar (Remediation)

- Keraksiz directory listing / admin endpointlarni cheklash (auth, allowlist).
- File upload'ni qat'iy validatsiya qilish (MIME, extension, content sniffing) va upload qilingan fayllarni execute bo'lmaydigan joyda saqlash.
- Web serverda `server-status` kabi servislarni faqat ichki tarmoqqa cheklash.

9) Ilova (Appendix)

- Ishlatilgan commandlar ro'yxati:

- `sudo arp-scan -l`
- `nmap -p- 10.172.97.93 -T4 -A`
- `gobuster dir -u http://10.172.97.93 -w /usr/share/wordlists/dirb/common.txt`

bu yerda menga `/usr/bin/man`

`ishga tushirish huquqi berilgan ekan u ozi bilan shel olib keladi va u root huquqlari bilan ishlagani uchun sheli ham rootniki boladi men shu orqali root bola oldim`